Intrusion Detection

MSI – MEI – MI – MDS
2024/2025

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Intrusion Detection (ID)

- Classically, ID encompasses all kinds of attempts to detect the presence or the likelihood of an intrusion
- ID can be performed in real-time or off-line
- It is directed at any or all of attacks (e.g., port scan detection), vulnerabilities (e.g., scanning), and intrusions (e.g., correlation engines)

- Definition of ID given by NSA (1998):

  "Pertaining to techniques which attempt to detect intrusion into a computer or network by observation of actions, security logs, or audit data. Detection of break-ins or attempts either manually or via software expert systems that operate on logs or other information available on the network."

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

ID History

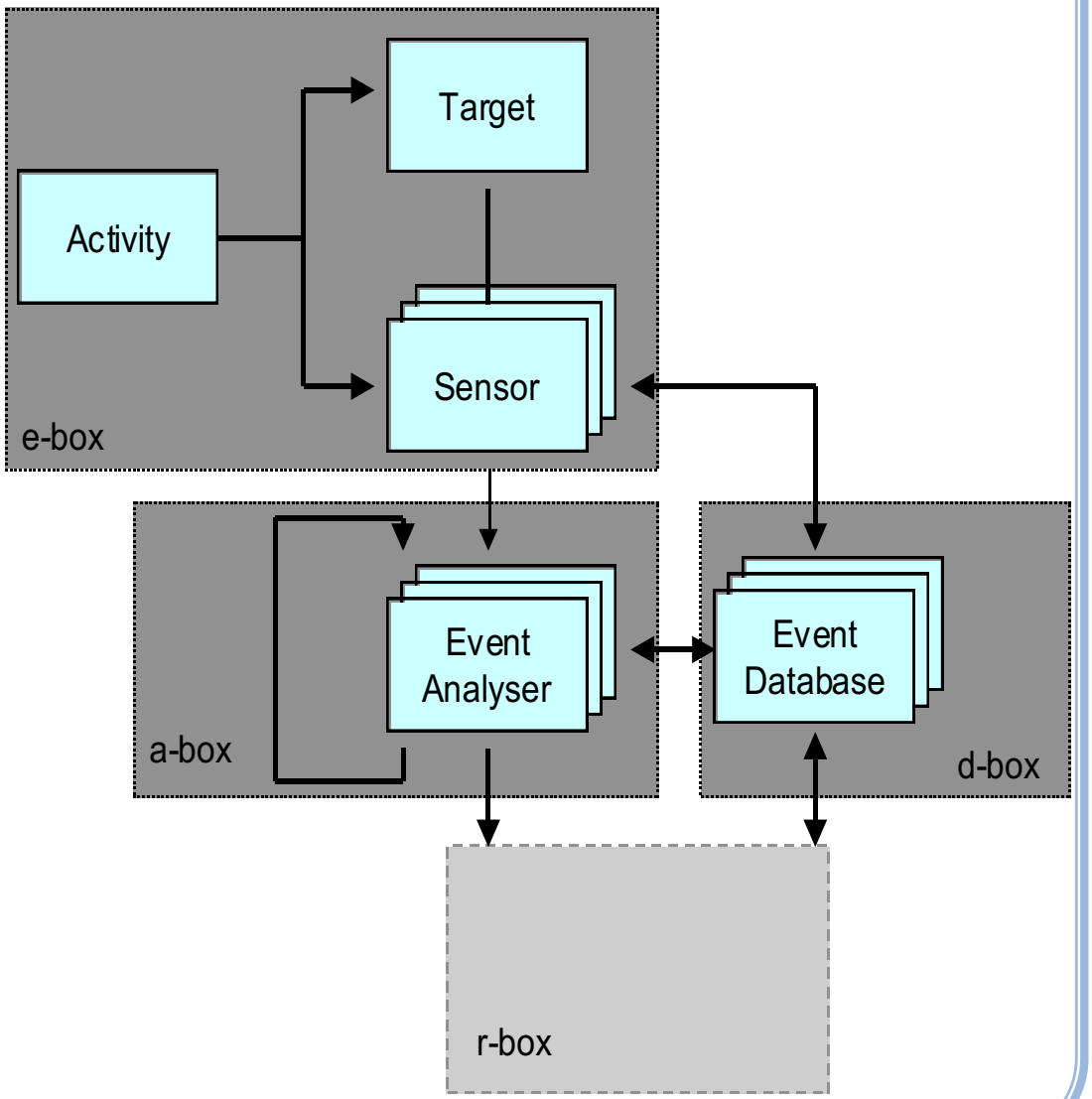
- Audit was important for financial systems in 60s
- J. Anderson report (1972) advocated the use of a surveillance system for collecting data that may indicate attempted or actual security violations
- Another J. Anderson report (1980) defines the info that must be collected, and how it could be analyzed
- Denning's model (1987) assumes that profiles can be established for users and that intrusions are deviations from these profiles
- First network-based ID system (IDS) (1990)
- DARPA puts lots of money on the field (90s)
- IDS output correlation and SIEMs (00s)
- Integration with external sources; threat intelligence; machine learning (10s)

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

CIDF (Common Intrusion Detection Framework)

- CIDF proposes a structure for intrusion-detection systems:
- e-box (event generator) gathers event information
- a-box (analysis box) analyses event information, detecting errors and diagnosing faults
- d-box (database) saves IDS persistent information
- r-box (response box) acts upon the results of analysis

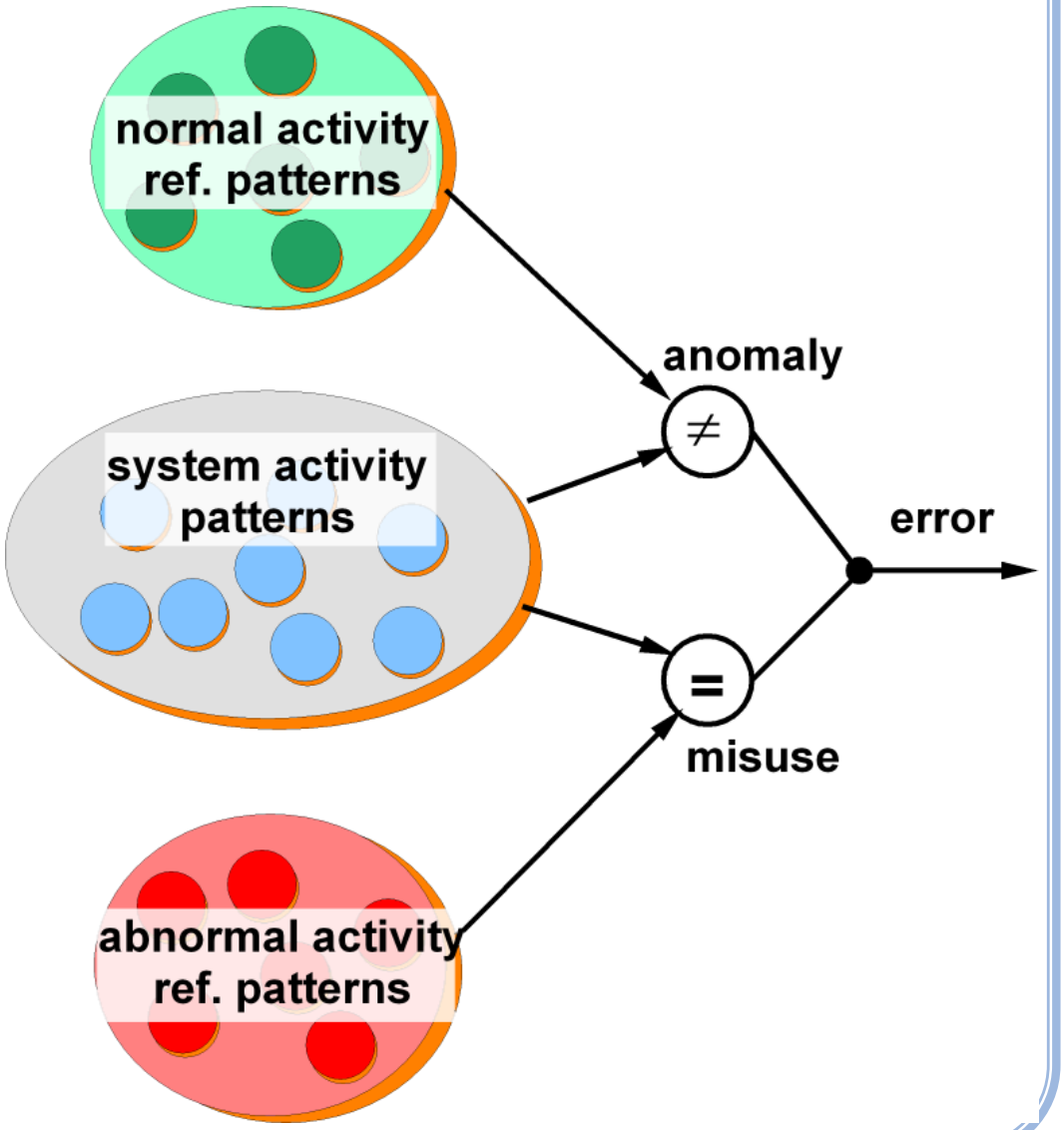
- *in fact, r-box is not intrusion detection, but error recovery and fault treatment*



Ciências ULisboa
©2010-25 P. Veríssimo and A. Bessani – All rights reserved.
INTOL

Detection mechanisms

- Consider system activity specified by patterns
- Anomaly detection
  - looks for deviation from NORMAL ACTIVITY PATTERNS
- Misuse detection
  - looks for existence of ABNORMAL ACTIVITY PATTERNS
- Both can be used with hosts, network, or (more recently) applications
- We can have hybrids



Ciências ULisboa
©2010-25 P. Veríssimo and A. Bessani – All rights reserved.
INTOL

Intrusion Detection = Signal Detection

- **Intrusion detection can be seen as an instance of the classical signal detection problem**
  - **Intrusion manifestations are the signal to be detected while manifestations of normal operations are the noise**
- **Classical signal detection problem**
  - **Both the signal and noise distributions are known a priori**
  - **A decision process must determine if a given observation belongs to the signal-plus-noise distribution or the noise distribution**
- **Intrusion detectors usually know only one of these distributions**
  - **Misuse detectors know the signal distribution**
  - **Anomaly detectors know the noise distribution**
  - **Anyway, both distributions are hard to characterize**

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

IDS Quality of Service

- **Intrusion detection is an applied classification problem**
  - **Classification problems are well studied in artificial intelligence and statistics**
- **IDSes are binary classifiers that identifies data entries (e.g., packets, network flows, attached files) as satisfying a giving property (e.g., it is an attack, it is infected) or not**
- **This leads to two failure modes:**
  - **False Positive - FP (the opposite of True Positive - TP): when something that does not have the property is classified as having the property**
  - **False Negative - FN (the opposite of True Negative - TN): when something that have the property is classified as not having the property**
- **IDS Quality of Service:**
  - **Sensitivity: the percentage of positive classification that are correct (TP rate)**
  - **Specificity: the percentage of negative classification that are correct (TN rate)**
- **A perfect IDS has** *sensitivity=specificity=100%*, **while the worst IDS flip a coin for each entry:** *sensitivity=specificity=50%*

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

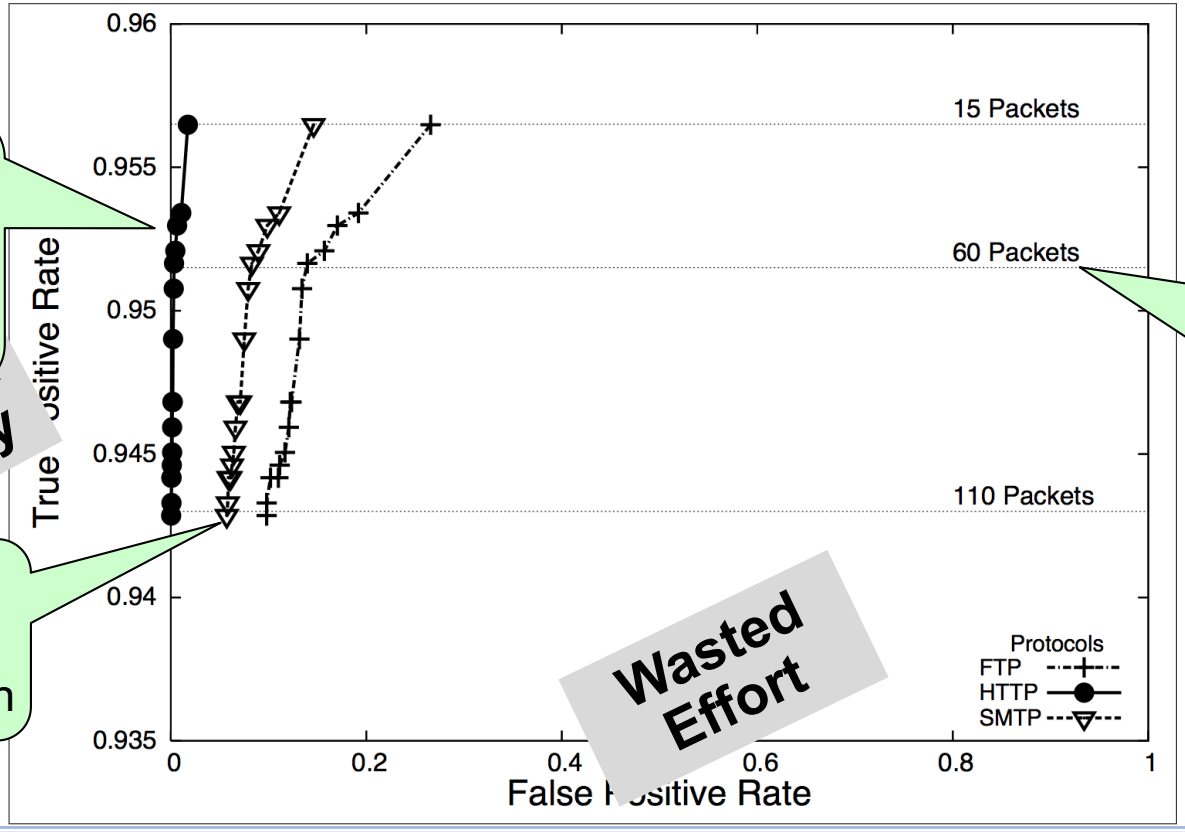
The ROC Curve

- **There is always a tradeoff between sensitivity and specificity**
- **This tradeoff is captured by the Receiver Operating Characteristic (ROC) curve, which plots sensitivity (TP rate) vs false positive rates (1 - specificity), using the Operating Characteristic as a control**

HTTP is easier to classify while SMTP is hard, and FTP is even harder

Detection Capacity

By using more packets we have better classification



Wasted Effort

Operating characteristic is the number of packets in a session, something we can control.

Ciências ULisboa

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

INTOL

The Base-Rate Fallacy

- Consider that after analyzing the ROC curve of a classifier, we setup an IDS with 99% true positive rate and 1% false positive rate
- After putting it in operation we receive an intrusion alert from the system

- What is the probability that the alert is a true positive?
  - It isn't 99%; the TP rate is the probability the IDS will raise an alert if an attack takes place! (a conditional probability)
  - This is the base-rate fallacy…

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

The Base-Rate Fallacy

- Let's define a test as the process an IDS uses to decide if it should raise an alert or not:
  - E.g.: verify 10 seconds of network traffic against a profile to see if it is an anomaly; verify if the first two packets of a flow contains a virus
- Assume the probability of an actual attack to take place is 0,01% (for every 10000 tests, one is an attack – one attack each ~28 hours)
- Going back to our (99%,1%) IDS:
  - For every 10000 tests, we will have one alarm due to an attack (due to our 99% of sensitivity)
  - However, the FP rate of 1% implies that the system raises one false alarm for every 100 tests
  - In 10000 tests, 101 alarms will be raised (one alarm each 17 minutes), and only one is an attack!
- <u>FP rates should be really low for an IDS to be useful</u>

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

IDS Classes

- **Behavior-based (or anomaly detection) systems**
  - no knowledge of specific attacks
  - provided with knowledge of normal behavior of monitored system, acquired, e.g., through extensive training of the system
  - advantages: they do not require a database of attack signatures that needs to be kept up-to-date; capable of detecting new attacks
  - drawbacks: potential false alarms; no info on type of intrusion, just that something unusual happened
- **Knowledge-based (or misuse detection) systems**
  - rely on a database of previously known attack signatures
  - whenever an activity matches a signature, an alarm is generated
  - advantage: alarms contain diagnostic information about cause
  - drawback: potential omitted or missed alarms, e.g., new attacks

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Anomaly Detection Techniques

- **Underlying assumptions:**
  - **Intrusive actions (attacks or intrusions) are <u>necessarily different</u> from non-intrusive actions at some level of observation**
  - **Intrusions will be accompanied by manifestations that are <u>sufficiently unusual</u> to allow detection**
- **Limitations**
  - **These assumptions can be broken by a highly-skilled attacker (advanced persistent threats)**
  - **How to efficiently model the noise (i.e., normal activities)?**

Style	Model	Method
Self-learning	Non time series	Rule-modeling
		Descriptive statistics
	Time series	Neural net
		Immune inspired
Programmed	Descriptive statistics	Simple statistics
		Simple rule based
		Threshold
	Default deny	State series modeling

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Misuse Detection Techniques

(most used in practice)

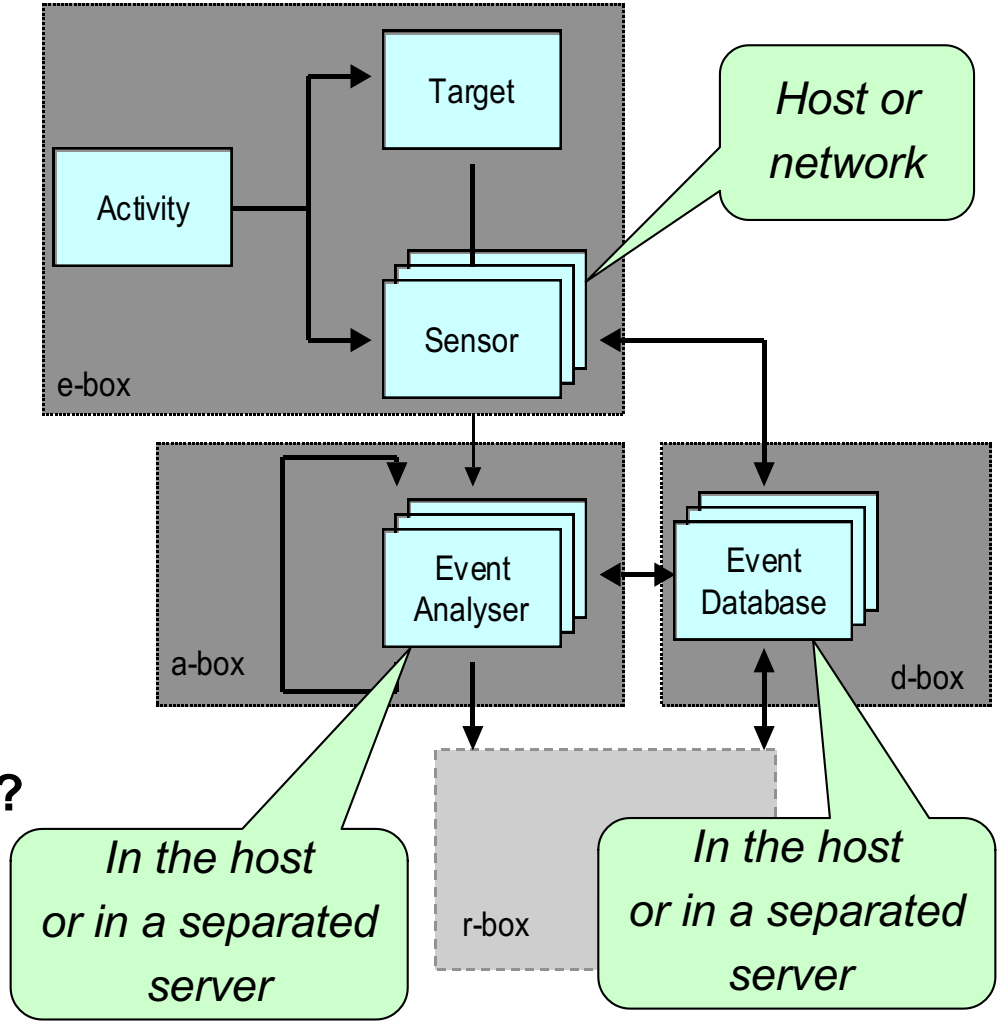
- **This relies on attack descriptions**
  - **Simple strings that will be matched with packets**
  - **State machines represent sequences of actions/packets**
  - **Neural network models**
- **Such descriptions can be**
  - **Very concrete (e.g., for a specific attack targeting a vulnerability)**
  - **Abstract representations of a class of attacks**
- **Limitations**
  - **The knowledge base must be kept up to date**
  - **No way to detect completely new attacks or zero-day vulnerabilities**

Style	Model	Method
Programmed	State modeling	State transition
		Petri net
	Expert system	
	String matching	
	Simple rule-based	

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Host-based vs. Network-based IDS

- **Host-based**
  - **e-box is a host**
  - **Collected info: session duration, commands, files accessed, etc.**
  - **Data collection should not be performance intrusive**
- **Network-based**
  - **e-box is "the network"**
  - **Collected info: packet headers, full packets, etc.**
  - **Data collection can be easily done with a promiscuous network interface**
- **Where is data analyzed and stored?**
- **Network-based more common:**
  - **It is easy to deploy and manage, right?**
  - **Is it more efficient?**



Ciências ULisboa
©2010-25 P. Veríssimo and A. Bessani – All rights reserved.
INTOL

Network IDS vs. Anti-Virus

- **Originally, Network IDSes were worried about intelligent adversaries**
- **This changed with the emergence of worms in 2000s**
- **Now, besides handcrafted rules, many worm-related attack signatures and botnet defenses are also used**
- **This makes a network IDS somewhat like a network Anti-Virus (also called IPS – Intrusion Prevention System)**

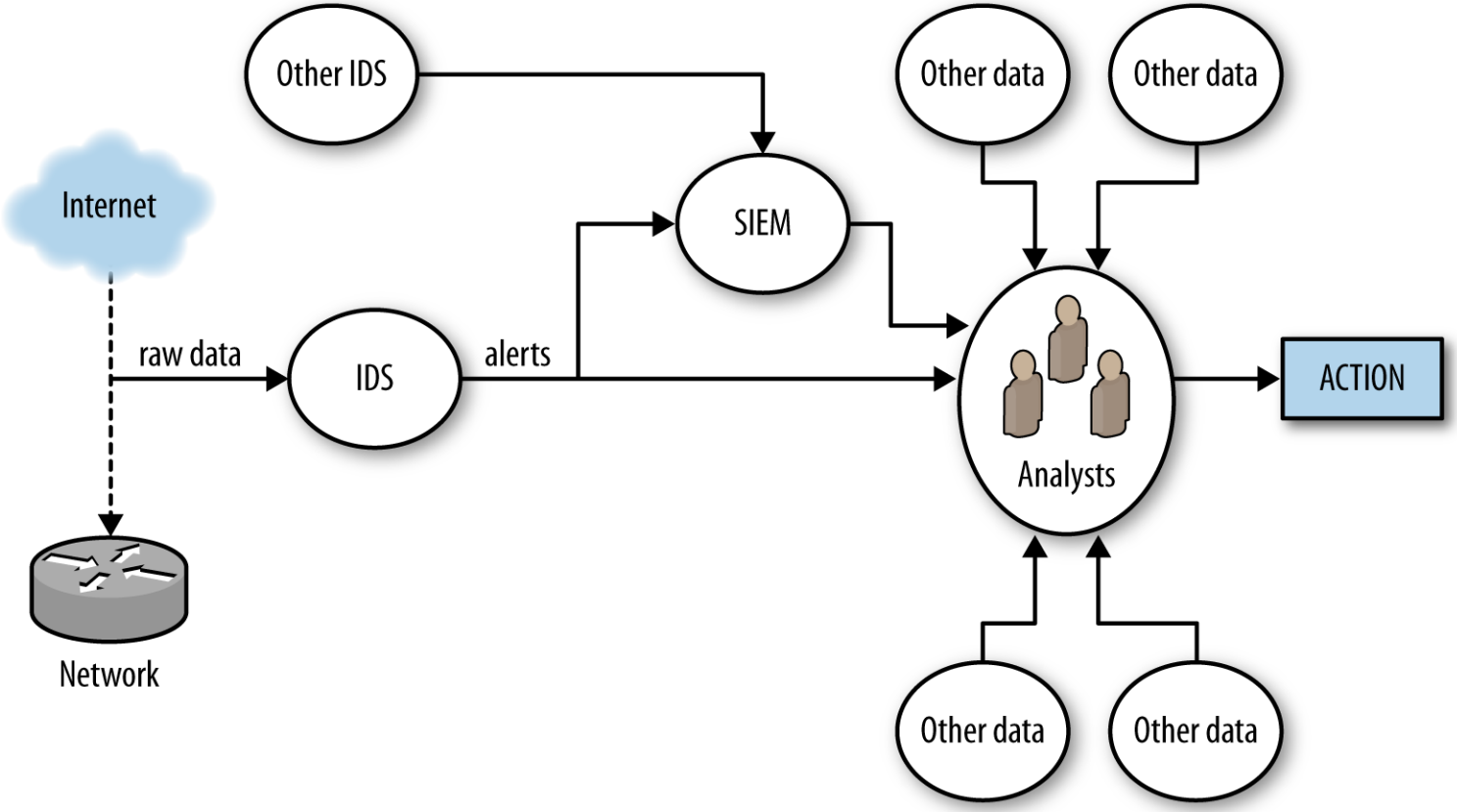
```
GET /default.ida?NNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNN
NNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNN
NNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNNN
NNNNNNNNNNNNNNNNNNNNNNN%u9090%u6858%ucbd3%u7801%u9090%u6858%ucbd3%u7801
%u9090%u6858%ucbd3%u7801%u9090%u9090%u8190%u00c3%u0003%u8b00%u531b%u53ff
%u0078%u0000%u00=a  HTTP/1.0
```

Code Red variations

```
GET /default.ida?XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
XXXXXXXXXXXXXXXXXXXXXX%u9090%u6858%ucbd3%u7801%u9090%u6858%ucbd3%u7801
%u9090%u6858%ucbd3%u7801%u9090%u9090%u8190%u00c3%u0003%u8b00%u531b%u53ff
%u0078%u0000%u00=a HTTP/1.0
```


©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Security Monitoring in Practice



- **IDS alert processing has three steps: IDS test data; generates an alert; the alert is sent to security analysts either directly or through a SIEM system**
- **There is always an interim analytical step between alert and action**

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Security Monitoring in Practice

- **What kind of analysis?**
  - Analysts must figure out what the alert means, which usually requires the execution of many queries on the collected data
    - » Why was the alarm triggered?
    - » Who is involved in the potential attack?
    - » Did it happen before?
    - » Do we have the packets payload?
  - Relate internal information with other data sources on the internet
    - » Are there a (new) vulnerability being exploited?
    - » Are there other reports about it?
- **There are systems and tools to help analysts gain context and investigate problems**
  - Integrating Open-source Intelligence (OSINT) information using machine learning is particularly challenging

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Some Open-Source Systems

- Snort
- Suricata
- Bro
- Kismet

} Network-based

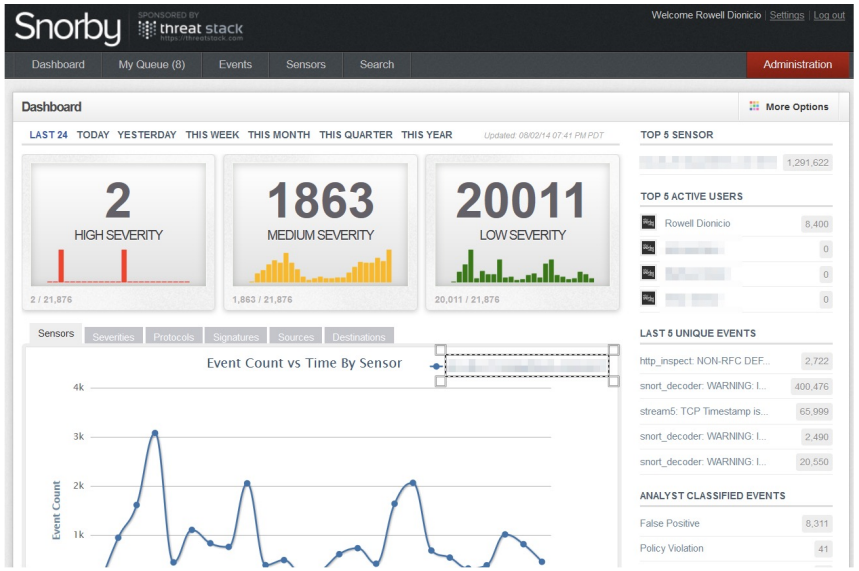
- OSSEC
- Samhain
- OpenDLP

} Host-based

https://www.alienvault.com/blogs/security-essentials/open-source-intrusion-detection-tools-a-quick-overview

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

- **Network-based misuse (signature-based) IDS**
- **Exists since 1998, now a de-facto standard for IDS**
- **Big signature database with large community support**
- **Lots of helpful tools (e.g., Snorby)**



Ciências ULisboa
©2010-25 P. Veríssimo and A. Bessani – All rights reserved.
INTOL

- **Network-based misuse (signature-based) IDS**
- **Uses the same signatures and rule syntax of SNORT**
- **More advanced than SNORT**
  - **Multi-threaded (SNORT is single-threaded)**
  - **Support hardware accelerators (e.g., GPUs)**
  - **Lua-based scripting engine**
  - **Logs more than packets (e.g., TLS/SSL certs, HTTP requests, DNS requests)**

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

- A host-based signature-based (misuse) IDS
- Agents capture events from the host and send them to a remote server for analysis and alert generation
  - Agents are very lightweight (1MB installer)
  - Reuse usual OS logging capabilities (e.g., syslog on Linux)
  - Available for virtually every OS
- The central server can also manage agents (to cope with big deployments)

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

Limitations of IDS

- In the 90s DARPA sponsored a substantial number of intrusion detection projects, with a clear goal for the proposed detectors:
  - 99% of the attacks should be detected
  - with less than 1% of false positive rate
- No system achieved that… some possible causes:
  - Systems based on intuitive but unfounded assumptions:
    - » Manifestations of certain kinds of intrusions would be so obvious that rules for detecting them could be written
    - » Deviations from "normal" behaviors would usually be definite indications of malicious or intrusive activity
  - Lack of theoretical foundations for the field
  - Modeling human behavior is inherently hard
- This is yet another reason why we need to explore the intrusion tolerance/survivability/resilience approach

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.

References

- J. McHugh. **Intrusion and intrusion detection.** International Journal of Information Security. 2001
- M. Collins. **Network Security Through Data Analysis: Building Situational Awareness (Chapter 7).** O'Reilly. 2014.
- Stefan Axelsson. **The base-rate fallacy and the difficulty of intrusion detection.** ACM Transactions on Information Systems Security 3(3). 2000.

©2010-25 P. Veríssimo and A. Bessani – All rights reserved.